

Descripción Técnica - Autoridad Certificadora

2023-07

Bitácora de cambios.....	3
Requisitos del sistema.....	4
Arquitectura del sistema.....	5
Diseño del sistema.....	6
Actores.....	6
Generación de Requerimiento.....	7
Generación de Certificado.....	11
Atributos.....	11
Vigencia.....	12
Firma.....	12
Entrega.....	12
Revocación de certificado.....	13
Razones de revocación.....	13
Revocación iniciada por Agente.....	14
Ejemplo de solicitud.....	15
Ejemplo de notificación.....	16
Revocación iniciada por Usuario.....	17
Ejemplo de solicitud.....	18
Ejemplo de notificación.....	19
Renovación de certificado.....	20
Renovación con certificado vigente.....	20
Ejemplo de solicitud.....	21
Ejemplo de notificaciones.....	22
Renovación con certificado no vigente.....	23
Consulta de certificado de Autoridad Certificadora.....	24
Ejemplo de solicitud.....	24
Ejemplo de respuesta.....	24
Consulta de certificado de usuario.....	25
Ejemplo de solicitud.....	25
Ejemplo de respuesta.....	25
Servidor OCSP.....	26

<u>Monitoreo de certificados.....</u>	<u>27</u>
<u>Notificaciones internas.....</u>	<u>27</u>
<u>Notificaciones por correo electrónico.....</u>	<u>28</u>
<u>Catalogo de errores.....</u>	<u>29</u>

Bitácora de cambios

Fecha	Descripción
2023-08-15	1. Webhooks contienen notification_type y notification_id 2. Revocación de certificado por usuario sólo se puede realizar firmando la solicitud con su certificado de la AC vigente 3. Se especifican las posibles razones de revocación de un certificado 4. Ejemplos de solicitud y respuestas de revocación 5. Ejemplos de solicitud y respuestas de renovación 6. Endpoint para obtener certificado de la AC 7. Endpoint para búsqueda de certificado por CURP
2023-11-27	Se agrega información sobre mailgun para envío de correos
2023-12-19	Se agrega catalogo de errores del API

Requisitos del sistema

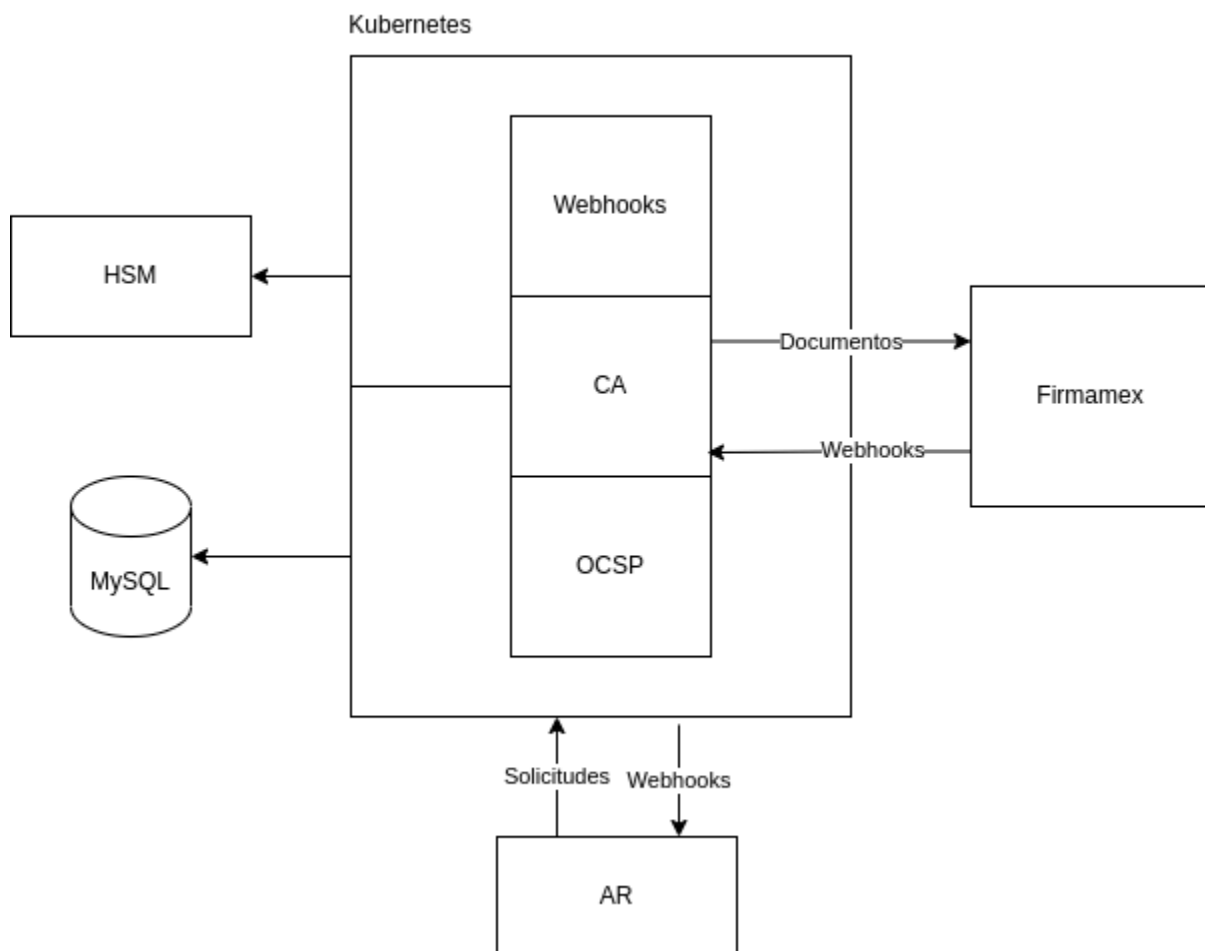
1. Generación de certificados X.509: El sistema será capaz de generar certificados X.509 a partir de un requerimiento firmado por un Agente autorizado
2. Revocación: Establecerá un procedimiento para revocar los certificados generados
3. Renovación: Establecerá un procedimiento para renovar los certificados generados
4. OCSP: Se deberá poder verificar la vigencia de los certificados generados por medio de consultas a un servidor OCSP
5. HSM: La llave de la autoridad será generada y resguardada dentro de un HSM
6. API: Se permitirá consumir los servicios de la Autoridad por medio de un API

Arquitectura del sistema

Se recomienda la siguiente Arquitectura para este servicio. El servicio de Webhooks, CA y OCSP montados dentro de un servicio de Kubernetes, para permitir su fácil escalabilidad.

La base datos MySQL sería un servicio externo, se recomienda que tenga alta disponibilidad y los controles necesarios para asegurar la seguridad de la información

Si se prefiere, el servicio de OCSP se puede montar por separado, ya que se requiere que se pueda alcanzar desde Internet



Diseño del sistema

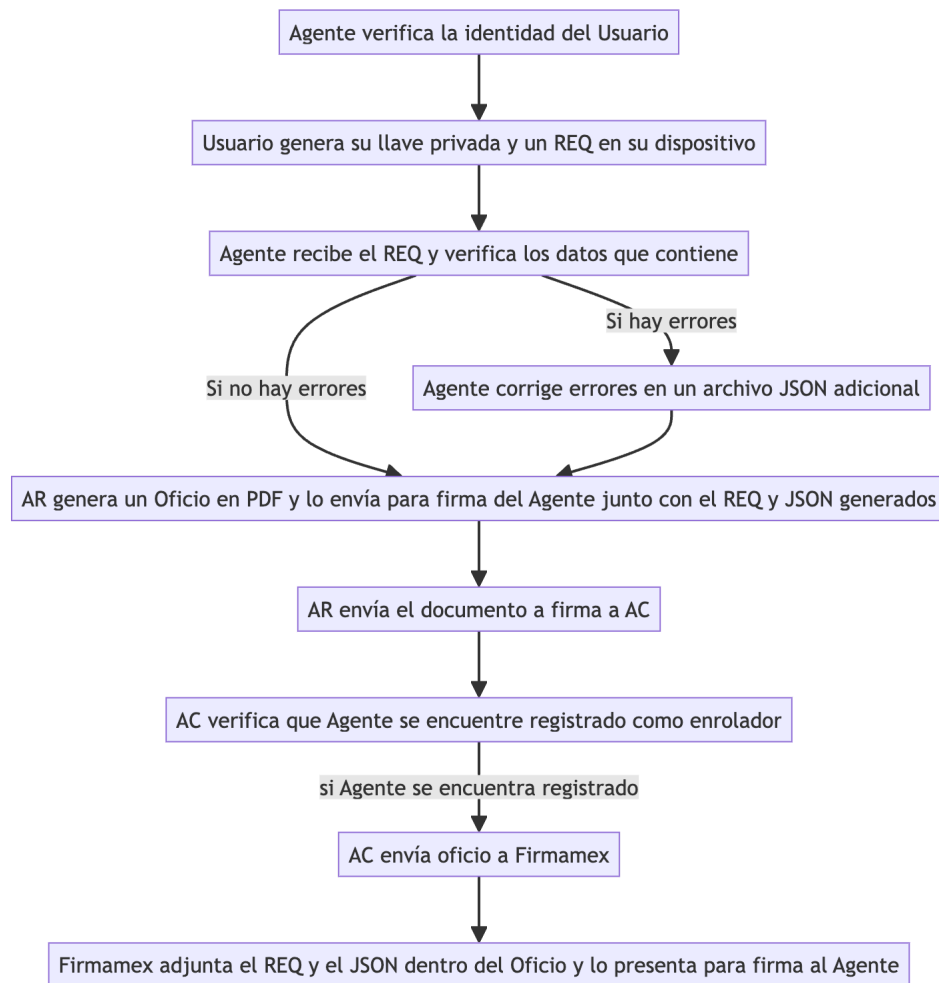
Actores

1. Autoridad Certificadora (AC): Servicio que se encargará de los servicios de:
 - a. Firma de requerimientos para generación de certificados
 - b. Exponer servicio de OCSP
 - c. Revocación de certificados
2. Agencia Registradora (AR): Existe entre la AC y los usuarios. Verifica a los usuarios y ayuda en la generación de los requerimientos de certificación
3. Firmamex: Servicio para generación y firma de documentos PDF
4. Agente: Persona autorizada para hacer uso de la AC por medio de la AR y generar, buscar o revocar certificados
5. Usuario: Persona interesada en obtener un certificado de la AC y utilizarlo como medio de identidad

Generación de Requerimiento

El requerimiento se generará directamente en el dispositivo del cliente junto con su llave privada. Esto asegurará que la llave nunca se exponga a nadie más que al usuario que la generó.

Después, el requerimiento se adjuntará en un Oficio que tendrá que firmar el Agente para autorizar la generación del certificado



La generación del requerimiento se realizará con la librería en javascript **firmamex-certs.js**. Esta librería podrá ser utilizada de la siguiente manera:

Generación de requerimiento:

JavaScript

```
// req y key serán los archivos correspondientes en PEM
const { req, key } = await firmamexCerts.generateReq(
  {
    name: "Juan Perez",
    email: "juan@dominio.com",
    rfc: "xxxx00000000xx",
    curp: "xxxx000000xxxxxx00",
  },
  '',
  {
    streetAddress: "calle",
    postalCode: "82111",
    localityName: "ciudad",
    stateOrProvinceName: "estado",
    countryName: "MX",
    organizationName: "O",
    organizationUnitName: "OU",
  }
);
```


Lectura de requerimiento:

JavaScript

```
// pkcs10 será un JSON con los atributos definidos en el req
const pkcs10 = firmamexCerts.readReq(req);
```

Envío del requerimiento:

El requerimiento será enviado junto con el Oficio que tendrá que firmar el Agente para autorizar la generación del certificado. Para esto, se utilizará el API de Firmamex, del cual se pueden utilizar las opciones publicadas en: <https://devs.firmamex.com/docs/>

Por ejemplo:

JavaScript

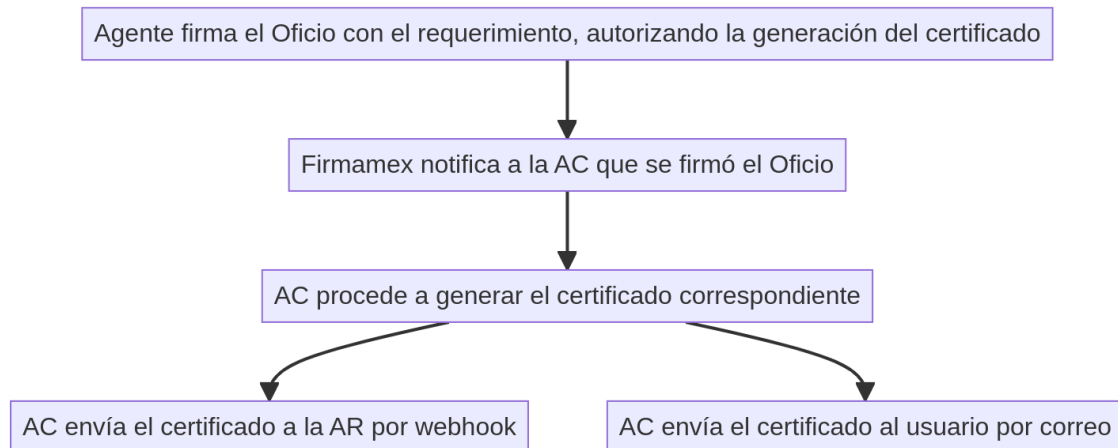
```
const FirmamexServices = require("./firmamex");
const services = FirmamexServices("webId", "apikey");
services.baseUrl = "https://url-ca";

const response = await services.request({
  b64_doc: {
    data: "documento codificado en base64",
    name: "Oficio Requerimiento XXX.pdf",
  },
  attachments: [
    {
      data: "LS0tLS1CRUdJ....",
      name: "prueba.req",
      mimeType: "application/pkcs10",
    },
    {
      data: "eyJjb21tb250....",
      name: "prueba.json",
      mimeType: "application/json",
    },
  ],
  stickers: [
    {
      authority: "Vinculada a Correo Electronico por Liga",
    }
  ]
});
```

```
    stickerType: "rect",
    dataType: "email",
    imageType: "stroke",
    data: "firmante@dominiodelfirmante.com",
    page: 0,
    rect: {
      lx: 330,
      ly: 300,
      tx: 530,
      ty: 400,
    },
  },
  l,
});
```

Generación de Certificado

La AC será notificada cuando el Oficio sea firmado por el Agente y generará el certificado correspondiente de manera automática



Atributos

El certificado contendrá los atributos del Usuario indicados en el requerimiento, los cuales pueden ser:

1. Nombre
2. Correo
3. Identificador único
4. Número de serie
5. País
6. Estado
7. Localidad
8. Organización
9. Unidad Organizacional

Adicionalmente, la CA agregará:

1. Número de serie
2. Nombre del emisor
3. Fecha de emisión
4. Vigencia
5. Políticas de uso
6. Dirección para consultas OCSP
7. Dirección para consulta de certificado emisor

8. La referencia de la tecnología empleada para la creación de la Firma Electrónica

Se puede consultar la estructura de estos atributos en el RFC 5280 de la IETF (<https://datatracker.ietf.org/doc/html/rfc5280>)

Vigencia

La vigencia será parte de la configuración de la AC, podrá establecerse en número de meses a partir de la fecha de emisión del certificado.

Firma

La firma del certificado se realizará por medio de PKCS11 utilizando el certificado guardado en el HSM

Entrega

Una vez que se haya generado el certificado. La AC hará entrega del mismo por dos medios:

1. A la AR por medio de webhooks: El webhook contendrá un JSON con el certificado en PEM y su Subject en texto plano. En caso de que la AR no pueda recibir el webhook, la AC seguirá reintentando con exponential backoff hasta obtener un HTTP 200 como respuesta. Ejemplo de webhook:

JavaScript

```
{
  "method": "POST",
  "headers": {
    "content-type": "application/json",
    "user-agent": "signmage webhooks",
    "accept-encoding": "gzip, deflate"
  },
  "body": {
    "certificate": "LS0tLS1CRUdJTiBDRVJUSUZJQ0...",
    "subject":
    "CN=Nombre,E=demo@correo.com,UniqueIdentifier=RFC,C=MX,SERIALNUMBER=CURP,O=0,ST
    REET=calle,L=localidad,PostalCode=CP",
    "notification_type": "certificate_signed",
    "notification_id": "0ba0b6d0-c0c2-4b66-a4ac-ea1269e65223"
  }
}
```

2. Al usuario por medio de correo electrónico

Revocación de certificado

Se ofrecerán dos métodos para la revocación de un certificado, las dos dependerán de un Oficio en el que se solicite la revocación del certificado. La diferencia entre los dos métodos, radica en si el oficio será firmado por un Agente o por el mismo Usuario

El envío del Oficio y su certificado se realizará usando las mismas herramientas del API de Firmamex que se usaron para el envío del requerimiento

Razones de revocación

Un certificado puede ser revocado por diferentes razones, las cuales pueden ser:

1. `keyCompromise`: La llave privada ya no puede considerarse segura
2. `cACompromise`: La Autoridad Certificadora no puede considerarse segura para este certificado
3. `affiliationChanged`: El usuario ya no está vinculado a la organización contenida en el certificado
4. `superseded`: Se generó otro certificado para reemplazar al actual
5. `cessationOfOperation`: El usuario o la Autoridad Certificadora ya no están en operación
6. `privilegeWithdrawn`: Se han revocado los derechos otorgados por medio del certificado al usuario
7. `unspecified`: Sin especificar

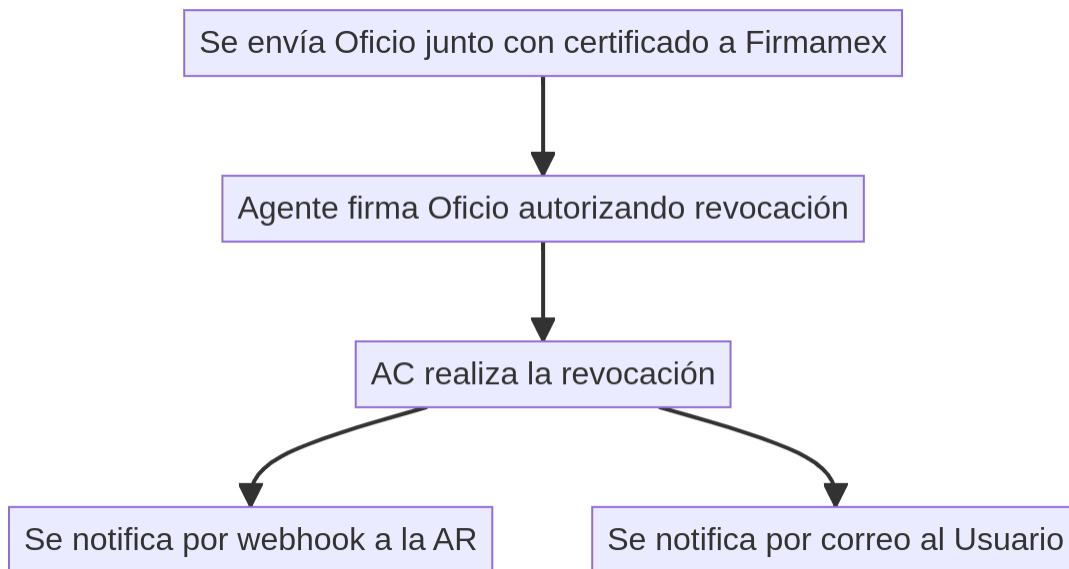
De la misma manera en que se pueden especificar atributos diferentes al requerimiento en un JSON al solicitar un certificado, se podrá especificar la razón de revocación en un JSON en la solicitud. El JSON tendrá que tener el siguiente formato

```
JavaScript
{
  "reason": "keyCompromise" // cualquiera de las razones anteriores
}
```

Si el JSON no se incluye en la solicitud, la razón de revocación será **unspecified**

Revocación iniciada por Agente

En caso de una revocación presencial. El Agente podrá generar un Oficio donde se solicite la revocación de un certificado a la AC.



Ejemplo de solicitud

JavaScript

```
const FirmamexServices = require("../firmamex");
const services = FirmamexServices("webId", "apikey");
services.baseUrl = "https://url-ca";

const response = await services.request({
  b64_doc: {
    data: "documento codificado en base64",
    name: "Oficio Revocacion XXX.pdf",
  },
  attachments: [
    {
      data: "LS0tLS1CRUdJ....",
      name: "certificado_para_revocar.cer",
      mimeType: "application/pkix-cert",
    },
    {
      data: "eyJjb21tb250....",
      name: "reason.json",
      mimeType: "application/json",
    },
  ],
  stickers: [
    {
      authority: "Vinculada a Correo Electronico por Liga",
      stickerType: "rect",
      dataType: "email",
      imageType: "stroke",
      data: "firmante@dominiodelfirmante.com",
      page: 0,
      rect: {
        lx: 330,
        ly: 300,
        tx: 530,
        ty: 400,
      },
    },
  ],
});
```

Ejemplo de notificación

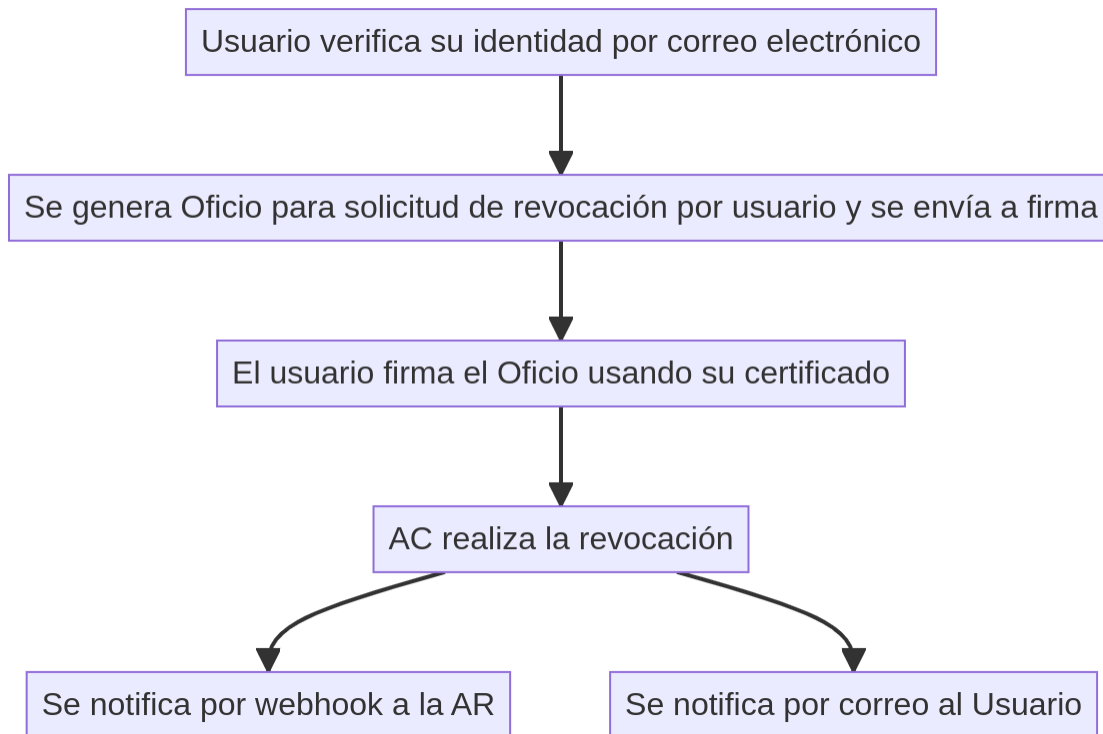
JavaScript

```
{
  "method": "POST",
  "headers": {
    "content-type": "application/json",
    "user-agent": "signmage webhooks",
    "accept-encoding": "gzip, deflate"
  },
  "body": {
    "certificate": "LS0tLS1CRUdJTiBDRV...",
    "subject":
      "CN=Nombre, E=demo@correo.com, UniqueIdentifier=RFC, C=MX, SERIALNUMBER=CURP, O=0, ST
      REET=calle, L=localidad, PostalCode=CP",
    "reason": "keyCompromise",
    "notification_type": "certificate_revoked_by_agent",
    "notification_id": "284e12b3-98ed-47f8-b307-f642b1a46fa6"
  }
}
```


Revocación iniciada por Usuario

Si se cumplen los requisitos para trámite en línea, el Usuario podrá realizar la revocación de su certificado de manera remota.

En este caso, el Usuario tendrá que verificar su identidad usando su propio certificado, y usar esta identidad para firmar el Oficio de solicitud de revocación.



Ejemplo de solicitud

JavaScript

```
const FirmamexServices = require("./firmamex");
const services = FirmamexServices("webId", "apikey");
services.baseUrl = "https://url-ca";

const response = await services.request({
  b64_doc: {
    data: "documento codificado en base64",
    name: "Oficio Revocacion XXX.pdf",
  },
  attachments: [],
  stickers: [
    {
      "authority": "Chihuahua", // certificado generado por la AC
      "stickerType": "line",
      "dataType": "rfc",
      "data": "XXXX000000XXX", // mismo RFC contenido en el certificado
      "imageType": "hash",
      "email": "demo@correo.com",
      "page": 0,
      "rect": {
        "lx": 74.88173,
        "ly": 312.32596,
        "tx": 196.9875,
        "ty": 373.37885
      }
    }
  ],
},
);
```

Ejemplo de notificación

JavaScript

```
{
  "method": "POST",
  "headers": {
    "content-type": "application/json",
    "user-agent": "signmage webhooks",
    "accept-encoding": "gzip, deflate"
  },
  "body": {
    "certificate": "LS0tLS1CRUdJTiBDRV...",
    "subject":
      "CN=Nombre,E=demo@correo.com,UniqueIdentifier=RFC,C=MX,SERIALNUMBER=CURP,O=0,STREET=calle,L=localidad,PostalCode=CP",
    "reason": "keyCompromise",
    "notification_type": "certificate_revoked_by_user",
    "notification_id": "284e12b3-98ed-47f8-b307-f642b1a46fa6"
  }
}
```

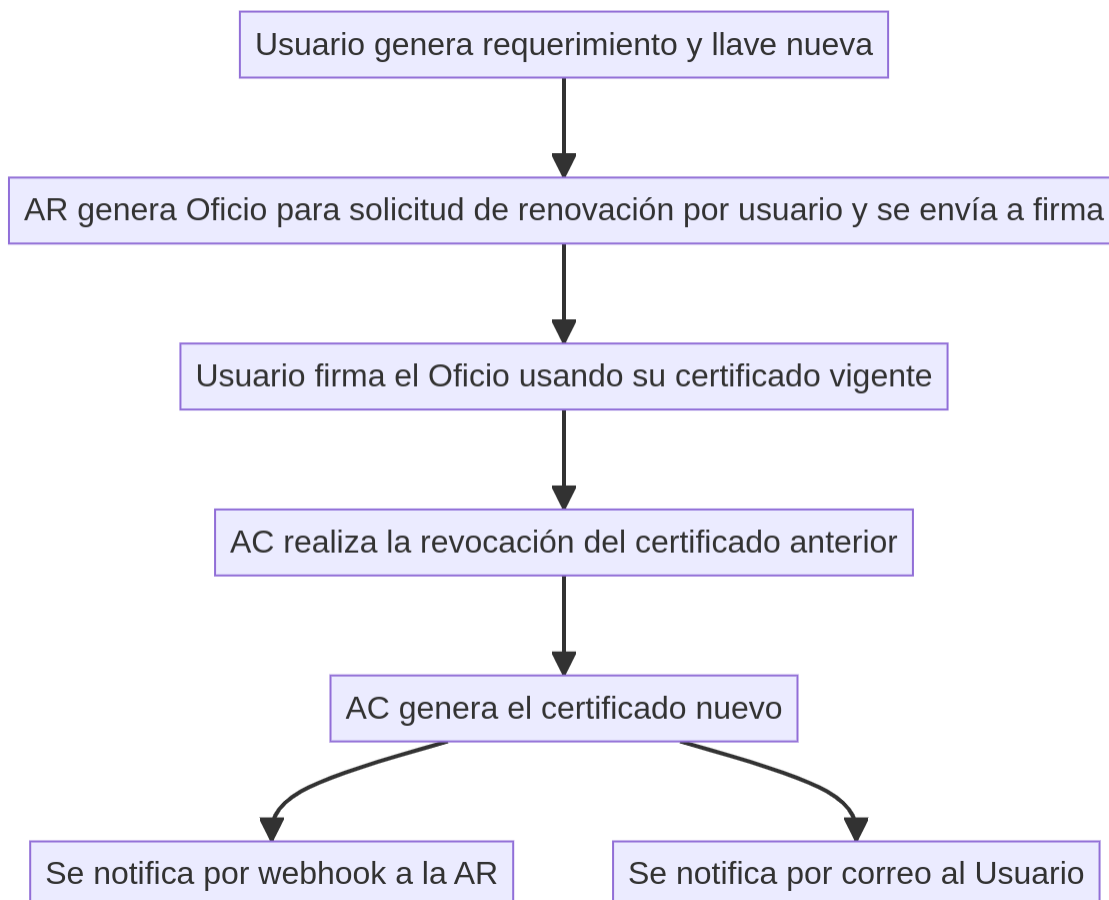
Renovación de certificado

Para la renovación de un certificado, primero se deberá generar un nuevo requerimiento y llave privada. Estos archivos se generarán con las mismas herramientas que se utilizaron para la generación inicial del certificado.

El requerimiento podrá o no contener datos adicionales a la llave pública. Si no los contiene, la AC generará el certificado nuevo con los mismos datos que el certificado anterior. Si los contiene, se reemplazarán estos datos en el certificado nuevo.

Renovación con certificado vigente

El Oficio para renovación tendrá que contener el certificado actual del usuario y el requerimiento para la generación del nuevo certificado



Ejemplo de solicitud

JavaScript

```
const FirmamexServices = require("./firmamex");
const services = FirmamexServices("webId", "apikey");
services.baseUrl = "https://url-ca";

const response = await services.request({
  b64_doc: {
    data: "documento codificado en base64",
    name: "Oficio Revocacion XXX.pdf",
  },
  attachments: [
    {
      data: "LS0tLS1CRUdJ....",
      name: "nuevo_req.req",
      mimeType: "application/pkcs10",
    },
    {
      data: "eyJjb21tb250....",
      name: "correcciones.json",
      mimeType: "application/json",
    },
  ],
  stickers: [
    {
      "authority": "Chihuahua", // certificado generado por la AC
      "stickerType": "line",
      "dataType": "rfc",
      "data": "XXXX000000XXX", // mismo RFC contenido en el certificado
      "imageType": "hash",
      "email": "demo@correo.com",
      "page": 0,
      "rect": {
        "lx": 74.88173,
        "ly": 312.32596,
        "tx": 196.9875,
        "ty": 373.37885
      }
    }
  ],
},
});
```

Ejemplo de notificaciones

Este proceso generará dos notificaciones: una de certificado revocado con razón de **superseded**, y otra del nuevo certificado firmado

JavaScript

```
{
  "method": "POST",
  "headers": {
    "content-type": "application/json",
    "user-agent": "signmage webhooks",
    "accept-encoding": "gzip, deflate"
  },
  "body": {
    "certificate": "LS0tLS1CRUdJTiBDRV...",
    "subject":
    "CN=Nombre,E=demo@correo.com,UniqueIdentifier=RFC,C=MX,SERIALNUMBER=CURP,O=0,ST
    REET=calle,L=localidad,PostalCode=CP",
    "reason": "superseded",
    "notification_type": "certificate_revoked_by_user",
    "notification_id": "284e12b3-98ed-47f8-b307-f642b1a46fa6"
  }
}
```

JavaScript

```
{
  "method": "POST",
  "headers": {
    "content-type": "application/json",
    "user-agent": "signmage webhooks",
    "accept-encoding": "gzip, deflate"
  },
  "body": {
    "certificate": "LS0tLS1CRUdJTiBDRV...",
    "subject":
    "CN=Nombre,E=demo@correo.com,UniqueIdentifier=RFC,C=MX,SERIALNUMBER=CURP,O=0,ST
    REET=calle,L=localidad,PostalCode=CP",
    "notification_type": "certificate_signed",
    "notification_id": "284e12b3-98ed-47f8-b307-f642b1a46fa6"
  }
}
```

Renovación con certificado no vigente

En caso de que el certificado ya haya expirado o haya sido revocado, el usuario no podrá generar el certificado nuevo por sí sólo, requerirá la intervención de un Agente para autorizar la generación del certificado nuevo. Teniendo el requerimiento generado, el resto del proceso de renovación será el mismo que el de generación del certificado por primera vez.

Consulta de certificado de Autoridad Certificadora

Es importante que el certificado de la Autoridad Certificadora pueda obtenerse para realizar verificaciones de los certificados firmados. Este certificado podrá encontrarse en el siguiente endpoint: `https://url-ca/[ac]/ca`

Ejemplo de solicitud

Unset

GET

`https://url-ca/chihuahua/ca`

Ejemplo de respuesta

Unset

Content-Type: **application/x-x509-ca-cert**

Content-Length: 1627

-----BEGIN CERTIFICATE-----

MIIEhDCCAzigAwIBAgIIMDAwMDAwMDAwQQYJKoZIhvcNAQEKMDsgDzANBglgghkgB
ZQMEAgEFAKEcMBoGCSqGSIB3DQEBCDANBglgghkgBZQMEAgEFAKIDAgEgMIGqMSIw
IAYDVQQDDb1DaGlodWFodWEgUm9vdCBDQSBURVNUSU5HMSkwJwYDVQQKDCBGaXJt
YW1leCBUZWNobm9sb2dpZXMGU0FQSSBkZSBkZSBDVjEaMBGGA1UECwwRU2VydmljaW8g
ZGUgRmlybWExCzAJBgNVBAYTAk1YMQswCQYDVQQHDAJDSEJmCEGCSqGSIB3DQEJ
ARYUc29wb3J0ZUBmaXJtYW1leC5jb20wHhcNMjMwNjI5MjAzODIwWhcNMjgwNjI5
MjAzODIwWjCBqjEiMCAgA1UEAwwZQ2hpaHVhaHVhIFJvb3QgQ0EgVEVTVEl0RzEp
MCCGA1UECgwRmlybWFTZGgVGVjaG5vbG9naWVzIFNBUEkgZGUgQ1YxGjAYBgNV
BAsMEVNlcnZpY2lvIGRlIEZpcm1hMQswCQYDVQQGEwJNWDELMAkGA1UEBwwCQ0gx

...

-----END CERTIFICATE-----

Consulta de certificado de usuario

Será posible obtener un certificado de un usuario de la Autoridad Certificadora realizando una consulta por el CURP contenido en el certificado: [https://url-ca/\[ac\]/cert/\[curp\]](https://url-ca/[ac]/cert/[curp])

En caso de que el certificado no se encuentre, o haya sido revocado, el endpoint contestará con un status code 404

Ejemplo de solicitud

Unset

GET

<https://url-ca/chihuahua/cert/OEAF771012HMCGR09>

Ejemplo de respuesta

Unset

Content-Type: **application/pkix-cert**

Content-Length: 1879

-----BEGIN CERTIFICATE-----

MIIEhDCCAzigAwIBAgIIMDAwMDAwMDAwQQYJKoZIhvcNAQEKMDSgDzANBgUghkgB
ZQMEAgEFAKEcMBoGCSqGSIb3DQEBCDANBgUghkgBZQMEAgEFAKIDAgEgMIGqMSIw
IAYDVQQDDb1DaG1odWFodWEgUm9vdCBDQSBURVNUSU5HMSkwJwYDVQQKDCBGaXJt
YW1leCBUZWNobm9sb2dpZXMGU0FQSSBkZSBkZjEaMBGGA1UECwwRU2VydmljaW8g
ZGUgRmlybWExCzAJBgNVBAYTAk1YMQswCQYDVQQHDAJDSEJmCEGCSqGSIb3DQEJ
ARYUc29wb3J0ZUBmaXJtYW1leC5jb20wHhcNMjMwNjI5MjAzODIwHhcNMjgwNjI5
MjAzODIwWjCBQjEiMCAgA1UEAwwZQ2hpaHVhaHVhIFJvb3QgQ0EgVEVTVEl0RzEp
MCCGA1UECgwRmlybWFFtZXggVG9jaG5vbG9naWVzIFNBUEkgZGUgQ1YxGjAYBgNV
BAsMEVN1cnZpY2lvIGR1IEZpcmlhMQswCQYDVQQGEwJNWDELMAkGA1UEBwwCQ0gx

...

-----END CERTIFICATE-----

Servidor OCSP

El protocolo OCSP (Online Certificate Status Protocol) es un protocolo utilizado para obtener el estado de revocación de un certificado digital X.509

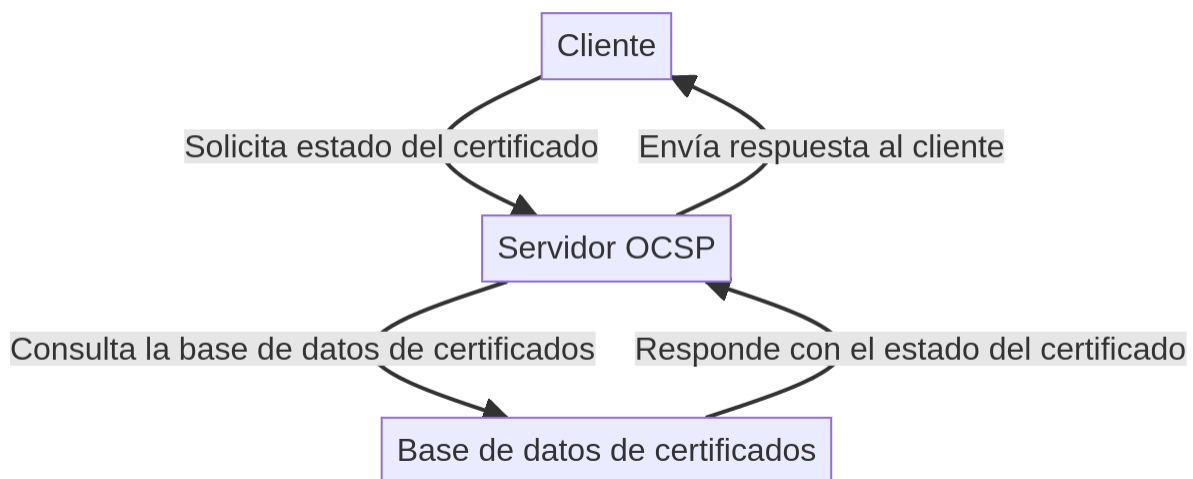
Para construir la solicitud, se requiere:

1. El certificado que se consultará
2. El certificado del emisor
3. La URL donde se puede alcanzar el servidor OCSP

Los certificados generados por la AC contendrán los elementos 2 y 3 directamente en sus atributos, por lo que cualquier herramienta podrá construir la solicitud sin información adicional

La respuesta a esta solicitud se firmará con un certificado autorizado para este proceso, por lo que el cliente podrá verificar si puede confiar en ella. La AC contendrá un procedimiento para generar este certificado fácilmente.

El flujo de verificación de un certificado por OCSP es el siguiente:



Monitoreo de certificados

La AC contará con un sistema de monitoreo para enviar notificaciones a los suscriptores cuando sus certificados hayan expirado.

También se podrán configurar notificaciones para cuando los certificados estén por expirar. Esta configuración se realizará directamente en la tabla de configuración de la AC en la base de datos:

Campo	Valor
EXPIRACION_NOTIFICACIONES	Días separados por coma, por ejemplo: 1, 5, 10. Enviaría una notificación cuando falten 10, 5 y 1 un día para que expire el certificado
EXPIRACION_FRECUENCIA	Número de horas, por ejemplo: 24. Indica que esta tarea se ejecutará cada 24 horas

Notificaciones internas

La AC podrá generar notificaciones las siguientes notificaciones para sus administradores:

1. Expiración de OCSP
2. Expiración de Autoridad

Notificaciones por correo electrónico

Para que la AC pueda enviar notificaciones de certificados emitidos, revocados, renovados, expirados o por expirar por correo electrónico, se requerirá darle acceso a Mailgun por medio su API con los siguientes campos en su configuración:

Campo	Valor
mailer.apikey	Llave del API de mailgun
mailer.from	Dirección origen de los correos, por ejemplo: =Gobierno del Estado de Chihuahua <ca@efirma.chihuahua.gob.mx>
mailer.domain	Dominio configurado en mailgun para los envíos de correo, por ejemplo: efirma.chihuahua.gob.mx

Catalogo de errores

Mensaje	Descripción	Solicitudes
error generating document	No fue posible enviar el oficio de solicitud al servicio de firma. Puede ser en la plantilla proporcionada, o en el servicio de firma	Todas
invalid request	No se reconoció el tipo de solicitud	Todas
invalid header	La solicitud no contiene el encabezado requerido de autenticación	Todas
invalid credentials	La solicitud no pasó el proceso de autenticación	Todas
signer not found on request	Se espera que la solicitud contenga un firmante, pero no se encontró ninguno	Revocación por usuario Renovación
certificate not found	No se encontró el certificado en la solicitud	Revocación por agente
missing required parameters	El requerimiento no contiene la información mínima requerida	Generación de certificado Renovación
certificate not valid	El certificado proporcionado no es válido, se encuentra revocado o expirado	Revocación por agente Revocación por usuario Renovación
certificate already exists	Se encuentra un certificado válido en este momento con los mismo datos	Generación de certificado
requirement not valid	No fue posible leer el req (pkcs10) contenido en la solicitud	Generación de certificado Renovación
user not authorized	Usuario no autorizado para la operación solicitada. Revisar tipo, firmante y contenido de la solicitud	Generación de certificado Revocación por agente
no attachments	Se esperaba algún archivo	Generación de certificado

	adjunto (attachment) en la solicitud, pero no fue encontrado	Revocación por agente
error getting req from json request	No se pudo extraer un archivo req de los attachments en la solicitud	Generación de certificado
error getting cert from json request	No se pudo extraer archivo cer de los attachments en la solicitud	Revocación por agente